

Task 1: Reconnaissance and Vulnerability Scanning

1. Task Explanation

Active reconnaissance and vulnerability scanning were performed on a safe and authorized TryHackMe test system. Nmap was used for port and service enumeration, and Nikto was used to perform a web vulnerability scan. The scan results were analyzed to identify potential security risks.

2. Tools Used

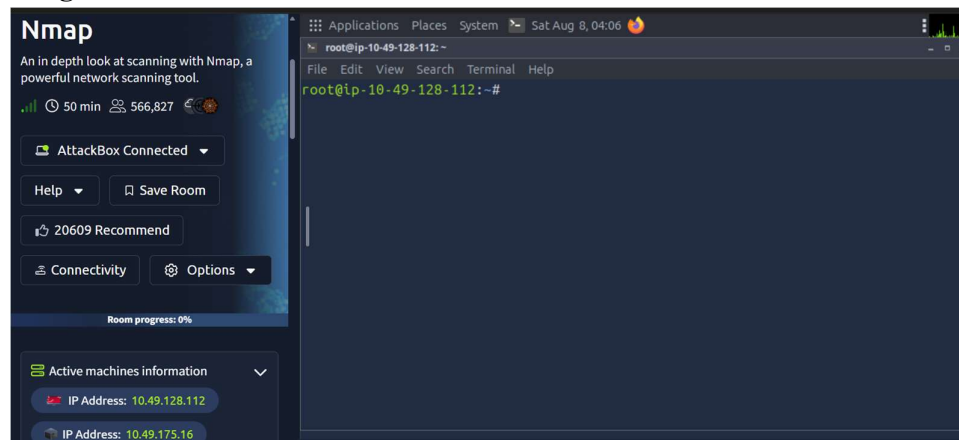
- TryHackMe
- Linux AttackBox
- Nmap
- Nikto

3. Procedure

Step 1: Deploy the Target Machine

The target machine was deployed in TryHackMe and the assigned target IP address was obtained.

Target IP: 10.49.175.16

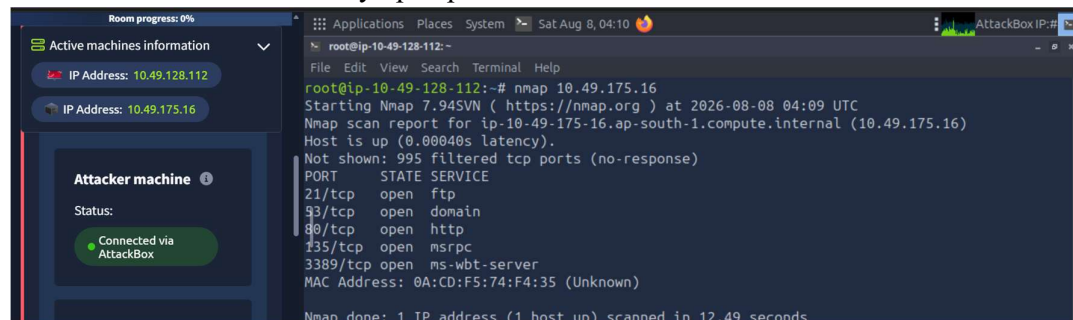


Step 2: Perform Port Enumeration

The following Nmap command was executed:

nmap 10.49.175.16

This scan was used to identify open ports and the services associated with them.

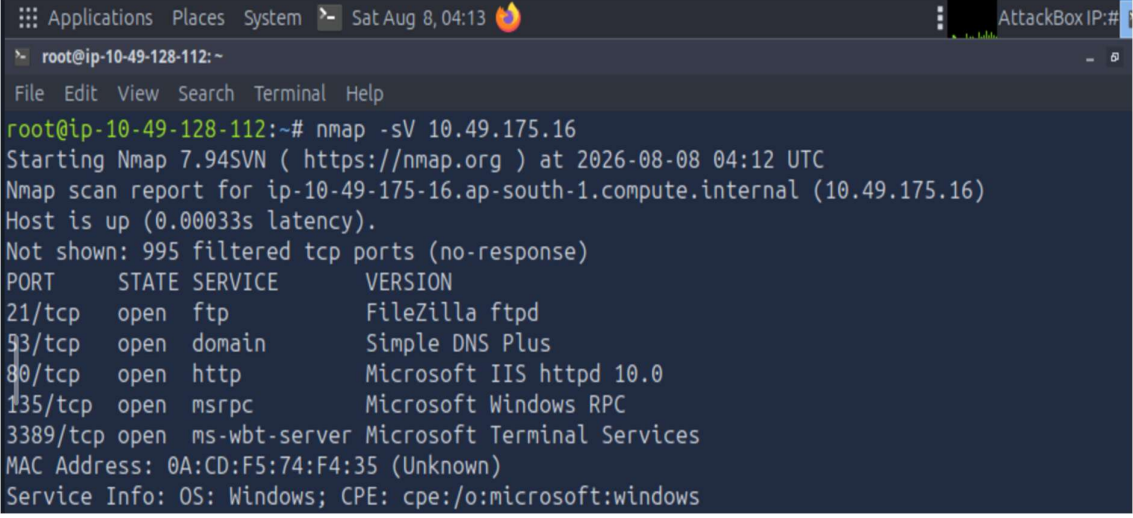


Step 3: Perform Service Enumeration

The following command was executed:

nmap -sV 10.49.175.16

The -sV option was used to identify the services and their versions running on the open ports.



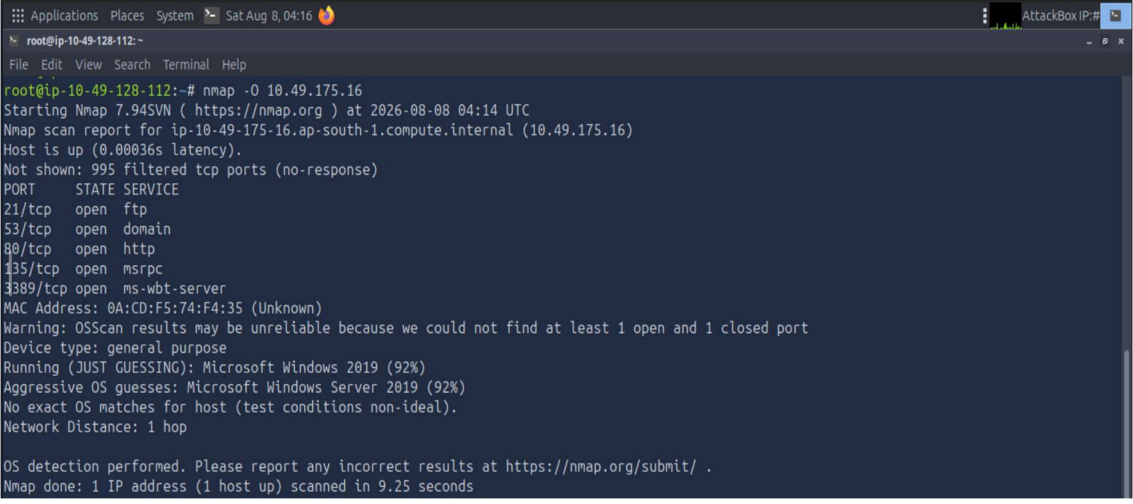
```
root@ip-10-49-128-112: ~  
File Edit View Search Terminal Help  
root@ip-10-49-128-112:~# nmap -sV 10.49.175.16  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-08-08 04:12 UTC  
Nmap scan report for ip-10-49-175-16.ap-south-1.compute.internal (10.49.175.16)  
Host is up (0.00033s latency).  
Not shown: 995 filtered tcp ports (no-response)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          FileZilla ftpd  
53/tcp    open  domain       Simple DNS Plus  
80/tcp    open  http         Microsoft IIS httpd 10.0  
135/tcp   open  msrpc        Microsoft Windows RPC  
3389/tcp  open  ms-wbt-server Microsoft Terminal Services  
MAC Address: 0A:CD:F5:74:F4:35 (Unknown)  
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```

Step 4: Perform Operating System Detection

The following command was executed:

nmap -O 10.49.175.16

The -O option attempts to identify the operating system of the target based on its network responses.



```
root@ip-10-49-128-112: ~  
File Edit View Search Terminal Help  
root@ip-10-49-128-112:~# nmap -O 10.49.175.16  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-08-08 04:14 UTC  
Nmap scan report for ip-10-49-175-16.ap-south-1.compute.internal (10.49.175.16)  
Host is up (0.00036s latency).  
Not shown: 995 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
53/tcp    open  domain  
80/tcp    open  http  
135/tcp   open  msrpc  
3389/tcp  open  ms-wbt-server  
MAC Address: 0A:CD:F5:74:F4:35 (Unknown)  
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port  
Device type: general purpose  
Running (JUST GUESSING): Microsoft Windows 2019 (92%)  
Aggressive OS guesses: Microsoft Windows Server 2019 (92%)  
No exact OS matches for host (test conditions non-ideal).  
Network Distance: 1 hop  
  
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 9.25 seconds
```

Step 5: Perform Detailed Nmap Scanning

The following command was executed:

nmap -A 10.49.175.16

The aggressive scan was used to gather additional information about the target, including service details and other network information.

```
Applications Places System Sat Aug 8, 04:18 AttackBox IP: #
root@ip-10-49-128-112:~# nmap -A 10.49.175.16
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-08-08 04:16 UTC
Nmap scan report for ip-10-49-175-16.ap-south-1.compute.internal (10.49.175.16)
Host is up (0.00037s latency).
Not shown: 995 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          FileZilla ftpd
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: TIMEOUT
|_ ftp-syst:
|_   SYST: UNIX emulated by FileZilla
98/tcp    open  domain       Simple DNS Plus
80/tcp    open  http         Microsoft IIS httpd 10.0
|_ http-server-header: Microsoft-IIS/10.0
|_ http-title: IIS Windows Server
|_ http-methods:
|_   Potentially risky methods: TRACE
135/tcp   open  msrpc        Microsoft Windows RPC
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
|_ ssl-date: 2026-08-08T04:17:48+00:00; 0s from scanner time.
rdp-ntlm-info:
|_   Target_Name: WIN-SCAN
|_   NetBIOS_Domain_Name: WIN-SCAN
|_   NetBIOS_Computer_Name: WIN-SCAN
|_   DNS_Domain_Name: win-scan
|_   DNS_Computer_Name: win-scan
|_   Product_Version: 10.0.17763
|_ System_Time: 2026-08-08T04:17:17+00:00
|_ ssl-cert: Subject: commonName=win-scan
|_ Not valid before: 2026-08-07T04:04:39
|_ Not valid after: 2027-02-06T04:04:39
MAC Address: 0A:CD:F5:74:F4:35 (Unknown)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2019 (92%)
Aggressive OS guesses: Microsoft Windows Server 2019 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

TRACEROUTE
HOP RTT      ADDRESS
1   0.37 ms ip-10-49-175-16.ap-south-1.compute.internal (10.49.175.16)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 51.44 seconds
```

Step 5: Perform Vulnerability Scanning

Nikto was used to scan the target's web service:

nikto -h 10.49.175.16

The scan was used to identify potential web-server vulnerabilities, insecure configurations, outdated components, and exposed files.

```
Applications Places System Sat Aug 8, 04:26 AttackBox IP: #
root@ip-10-49-128-112:~# nikto -h 10.49.175.16
- Nikto v2.1.5

+ Target IP: 10.49.175.16
+ Target Hostname: ip-10-49-175-16.ap-south-1.compute.internal
+ Target Port: 80
+ Start Time: 2026-08-08 04:25:23 (GMT0)

+ Server: Microsoft-IIS/10.0
+ Server leaks inodes via ETags, header found with file /, fields: 0x67d079d113b3d61:0
+ The anti-clickjacking X-Frame-Options header is not present.
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Server banner has changed from 'Microsoft-IIS/10.0' to 'Microsoft-HTTPAPI/2.0' which may suggest a WAF, load balancer or proxy is in place
+ Allowed HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST
+ Public HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST
+ 6544 items checked: 0 error(s) and 4 item(s) reported on remote host
+ End Time: 2026-08-08 04:25:36 (GMT0) (13 seconds)

+ 1 host(s) tested
```

4. Findings

The reconnaissance scans provided information about the target's exposed attack surface.

- Nmap identified the open ports on the target.
- Service enumeration identified the services and versions running on the open ports.
- OS detection attempted to identify the target's operating system.
- The aggressive scan provided additional information about the target.
- Nikto was used to identify potential web-server vulnerabilities and security misconfigurations.

5. Security Risks

The discovered services may present the following security risks:

- Open ports: Unnecessary open ports can increase the attack surface.
- Outdated services: Older service versions may contain known vulnerabilities.
- Exposed web services: Insecure web-server configurations may provide opportunities for attacks.
- Information disclosure: Service and version information can help attackers identify potential weaknesses.
- Web vulnerabilities: Vulnerable web-server components or configurations may expose the system to further attacks.

6. Recommendations

- Close unnecessary open ports.
- Disable unused services.
- Keep services and software updated.
- Configure firewalls to restrict unauthorized access.
- Fix vulnerabilities identified by Nikto.
- Perform regular vulnerability assessments.
- Minimize unnecessary service and version information disclosure.

7. Result

Active reconnaissance and vulnerability scanning were successfully performed on the authorized TryHackMe target using Nmap and Nikto. Open ports and services were enumerated, and the web service was assessed for potential security weaknesses. The findings were analyzed and appropriate security recommendations were provided.